

Caso de Auditoría: La importancia crítica de la segmentación de red.

Responsable: Lautaro Figueroa

Contexto: Auditoría interna en un cliente del sector agrario.

Hallazgo principal: Red plana sin ningún tipo de segregación lógica o física.

Fundamento Técnico.

La segmentación de red no es un control perimetral, sino un control internamente orientado. Su propósito es triple:

- **Reducción de superficie de ataque:** Cada segmento expone solo los servicios necesarios para su función. Un servidor contable no necesita hablar con una impresora de recepción.
- **Contención de propagación:** Limita el movimiento lateral ante un compromiso. El radio de explosión de un incidente se reduce al segmento afectado.
- **Aplicación de controles por contexto:** Permite políticas de seguridad diferenciadas según la criticidad del activo. Por ejemplo: segmento gerencial con MFA obligatorio, activos IoT con acceso nulo a internet.

Situación encontrada en Auditoría.

Escenario: Red corporativa configurada con una única subred /24 (192.168.1.0/24). Todos los activos (estaciones de trabajo, servidores, cámaras, teléfonos VoIP, impresoras y puntos de acceso Wi-Fi) conviven en el mismo dominio de broadcast.

Hallazgos derivados:

- **Inexistencia de políticas internas:** El firewall perimetral filtra tráfico saliente/entrante, pero no existen ACLs entre grupos funcionales dentro de la organización.
- **Acceso verificable desde área de Recepción:** Durante las pruebas de reconocimiento interno, se constató que desde un equipo del área de recepción se podía alcanzar y comunicar con todos los dispositivos de la red, incluyendo:
 - Impresora de uso común (IM 430): Con los siguientes puertos abiertos (80, 139, 445, 9100) .
 - Impresora de Gerencia(HP M402): Accesible sin restricciones de origen. Puertos abiertos (80, 443, 525, 9100).

Vulnerabilidades identificadas en los activos:

- **CVE-2021-33698** (Impresora de gerencia HP M402). El vector de ataque resulta en una ejecución remota de código (RCE) en el plugin WS-Addressing de Genivia gSOAP versión 2.8.107. Una petición SOAP especialmente diseñada, enviada a través del puerto 80 (HTTP), puede desencadenar la ejecución de código arbitrario en el dispositivo.
- **CVE-2009-3103** SMBv2 (Impresora uso general IM 430). El vector de ataque es una vulnerabilidad en el controlador srv2.sys del protocolo SMBv2 en sistemas windows. El componente afectado presenta una falla que permite a un atacante remoto no autenticado provocar una denegación de servicio (BSOD) o, en condiciones específicas, ejecutar código arbitrario en el sistema operativo subyacente. La vulnerabilidad se activa mediante el envío de paquetes SMBv2 especialmente manipulados.

Cadena de ataque demostrada.

La combinación de red plana + IoT vulnerable habilita el siguiente escenario de ataque con alta probabilidad de éxito.

Fase	Acción del atacante	Detalle técnico
1. Compromiso inicial	Phishing a un usuario de Recepción	El equipo de Recepción es un punto de entrada de bajo privilegio y alta exposición a correos externos.
2. Movimiento lateral	Escaneo de red interna	Desde el equipo comprometido, se escanea la subred /24 descubriendo todas las impresoras, cámaras y servidores.
3. Explotación de IoT	Envío de petición SOAP maliciosa a impresora de Gerencia	Se explota CVE-2021-33698 mediante HTTP contra la IP de la impresora de Gerencia.

4. Pivote a red de Gerencia	Uso de la impresora como punto de entrada	La impresora comprometida actúa como proxy o foothold para atacar equipos de la alta dirección, ya que se encuentra en su mismo entorno de red.
5. Exfiltración o ransomware	Acceso a información sensible	Desde la impresora se pueden atacar estaciones de trabajo de Gerencia, acceder a archivos críticos o desplegar ransomware.

Riesgo real materializado

El verdadero riesgo no es la vulnerabilidad de la impresora en sí misma, sino que:

- Una impresora de Gerencia está expuesta a toda la red sin ningún filtro de origen.
- Un equipo de Recepción (zona no confiable) puede comunicarse directamente con dispositivos de alta criticidad.
- No existen capas de defensa entre el punto de entrada y los activos sensibles.

Propuesta de remediación

Segmentación por departamentos (VLANs) - Crítico

Crear VLANs lógicas que aíslen por función y criticidad:

VLAN	Función	Subred	Acceso restringido
10	Gerencia / Dirección	10.0.10.0/24	Solo equipos autorizados
20	Contable / RRHH	10.0.20.0/24	Sin acceso a VLAN 10
30	Recepción / Operaciones	10.0.30.0/24	Sin acceso a VLANs 10, 20, 40
40	Servidores críticos	10.0.40.0/24	Solo puertos específicos desde VLANs autorizadas

99	IoT (Impresoras, cámaras)	10.0.99.0/24	Sin acceso a Internet ni a VLANs internas
----	---------------------------	--------------	---

Reglas de firewall interno

Implementar ACLs específicas para el tráfico entre segmentos:

Origen	Destino	Puertos permitidos	Justificación
VLAN 30 (Recepción)	VLAN 99 (Impresoras)	9100 (raw print)	Solo impresión, sin administración
VLAN 10 (Gerencia)	VLAN 99 (Impresoras)	9100, 80, 443	Administración limitada a Gerencia
Cualquier VLAN	VLAN 99	DENEGADO a puertos 80/443/21/22	Bloquear administración de IoT desde redes no autorizadas

Hardening de dispositivos IoT

- Actualización de firmware: aplicar parches para CVE-2021-33698 y CVE-2009-3103
- Cambio de credenciales: eliminar usuarios por defecto en todas las impresoras.
- Aislamiento inmediato del puerto SMB 445: bloquear tráfico entrante hacia el puerto 445 de las impresoras desde cualquier VLAN que no sea la de administración autorizada.
- Deshabilitación de SMBv2 en el dispositivo: desactivar el soporte para SMBv2 o migrar a alternativas más seguras como IPP/S.
- Deshabilitar servicios innecesarios: WS-Addressing/SOAP si no es requerido para la operación.
- Microsegmentación extrema: aislar cada impresora con su propia VLAN o utilizar Private VLAN para que los dispositivos IoT no puedan comunicarse entre sí, limitando el movimiento lateral incluso dentro del segmento IoT.
- Monitoreo: registrar intentos de acceso a puertos administrativos de impresoras desde IPs no autorizadas.

Conclusión.

Este hallazgo ejemplifica por qué la segmentación es el control más subestimado en entornos corporativos. No se trata solo de aislar departamentos, sino de romper la cadena de ataque antes de que un compromiso en un área de bajo privilegio (Recepción) pueda escalar a activos críticos (Gerencia) utilizando dispositivos IoT como puente.

La vulnerabilidad CVE-2021-33698 es grave, pero el verdadero riesgo radica en que cualquier equipo de la red puede alcanzar la impresora de Gerencia. Esto revela que una impresora comprometida puede ser utilizada como pivote hacia el segmento más sensible de la organización.